ABDELRHMAN SADAT KAWTHER

GRC MANAGER - INFORMATION SECURITY LEAD

Cairo, Egypt | +201000055639 | eng_a.sadat@hotmail.com | https://www.linkedin.com/in/abdelrhman-sadat-a92276aa/

PROFESSIONAL SUMMARY

Governance, Risk, and Compliance (GRC) and Information Security Leader with 5+ years of progressive experience across governance, risk, compliance, Security Operations Center (SOC) operations, and offensive security. Led cross-functional teams of 8-12 members across IT, Legal, and Operations and delivered GRC programs for 20+ banking, fintech, and regulated-sector clients including Tier 1 banks and payment processors. Expertise across Payment Card Industry Data Security Standard (PCI DSS), ISO 27001 and ISO 27701, General Data Protection Regulation (GDPR), SOC 2, NIST Cybersecurity Framework (NIST CSF), Central Bank of Egypt (CBE), Saudi Central Bank (SAMA), National Cybersecurity Authority (NCA), Financial Regulatory Authority (FRA), and other cybersecurity frameworks. Strong track record in risk assessment, risk quantification, control mapping, control testing, audit readiness, regulatory reporting, third-party risk management, business continuity, policy development, change management, metrics and KPIs, and executive reporting. Hands-on expertise in Qualys VMDR, ServiceNow GRC, and Archer Integrated Risk Management (IRM) as primary system owner, with the ability to translate technical risk into business impact for senior leadership, Data Privacy Officer, and board stakeholders.

CORE COMPETENCIES

GRC Leadership: Team Leadership, Stakeholder Management, Strategic Planning, Audit Management, Executive Reporting, Regulatory Reporting, Metrics and KPIs

Risk Management: Risk Assessment, Risk Registers, Risk Quantification, Risk Appetite, KRI and KPI, Control Libraries, Risk Treatment, Third-Party Risk Management, NIST CSF

Compliance and Assurance: PCI DSS, ISO 27001, ISO 27701, GDPR, SOC 2, NIST CSF, CBE, SAMA, NCA, FRA, Business Continuity, Control Testing, Internal and External Audit

Technical GRC: Control Mapping, Control Testing, Vulnerability Management, Policy and Procedure Development, Regulatory Assessments, Regulatory Reporting, Change Management

GRC Platforms: Archer IRM Platform Administration and System Ownership, ServiceNow GRC, Risk Workflow Automation, Compliance Dashboards

Security Operations: QRadar, Splunk, Wazuh, Cortex XSOAR, Trellix, Incident Response, Threat Intelligence

Offensive Security: Web, Mobile and Network Penetration Testing, Vulnerability Assessment, Risk-based Remediation

Technology: Qualys VMDR, Python, Java, C#, Windows Server, Active Directory, Linux

PROFESSIONAL EXPERIENCE

GRC Consultant

Spark, Egypt | Jul 2024 - Present

- Lead end-to-end GRC engagements for 20+ clients including Tier 1 banks, fintech payment processors, and regulated-sector enterprises with 500-5000 employees.
- Deliver compliance programs across Payment Card Industry Data Security Standard (PCI DSS), ISO 27001 and ISO 27701, General Data Protection Regulation (GDPR), SOC 2, NIST Cybersecurity Framework (NIST CSF), CBE, SAMA, NCA, FRA, and other cybersecurity frameworks.
- Manage risk assessments, risk registers, risk quantification, control libraries, control mapping, control testing, remediation plans, and audit evidence to drive 100 percent audit readiness for first-time certification and recertification across client engagements.
- Administered Archer Integrated Risk Management platform, serving as primary system owner for 20+ client implementations. Automated risk workflows, control tracking, regulatory reporting, and compliance dashboards. Reduced manual reporting by 60 percent. Evaluated ServiceNow GRC for workflow alignment.
- Lead cross-functional teams of 8-12 members across IT, Information Security, Legal, Operations, and business functions to close audit and compliance findings within agreed deadlines, including change management and business continuity requirements.
- Present risk findings, control gaps, remediation priorities, metrics and KPIs, and compliance status to C-suite and senior stakeholders, translating technical exposure into business impact.
- Develop and review information security policies, procedures, standards, third-party risk management processes, and governance documentation aligned with regulatory and industry requirements. Collaborated with Data Privacy Officer on privacy controls.
- Coordinate internal and external audit activities, evidence collection, management responses, and remediation tracking, achieving zero major non-conformities.
- Deliver compliance awareness and training sessions to 200+ staff, contributing to a 35 percent improvement in policy adherence.

SOC Analyst Level 2 (L2)

Optima Professional Services, Egypt | Oct 2022 - Jul 2024

- Supervised team of 5 Level 1 (L1) analysts reporting to SOC Manager. Standardized investigation playbooks, reducing escalations to Level 3 (L3) by 40 percent.
- Automated security alert triage and response workflows using Cortex XSOAR, reducing manual workload by 50 percent.
- Investigated security incidents and breach cases using forensic methodology and produced actionable root-cause and remediation reports.
- Integrated threat intelligence feeds and supported risk-based prioritization of patching and remediation against active threats.
- Applied Qualys VMDR to identify, prioritize, track, and remediate vulnerabilities across client environments.

Cybersecurity Engineer

Paymob, Egypt | Jul 2022 - Oct 2022

- Conducted web and mobile penetration testing covering OWASP Top 10 and prepared remediation reports adopted by development teams. 15 high-severity findings remediated within 30 days.

- Supported SOC monitoring and delivered phishing awareness sessions to 100+ employees.

IT Help Desk Support

Valeo Egypt, Egypt | Dec 2021 - Jul 2022

- Resolved Active Directory and McAfee issues, managed 20+ Jira tickets daily with 95 percent SLA compliance, and supported 300+ end-users across Windows and Linux environments, building foundational IT and access management skills.

SELECTED PROJECTS

PCI DSS Compliance Program for Tier 1 Fintech Payment Processor

6-month engagement

- Led implementation and readiness activities including gap assessment, control mapping, control testing, evidence coordination, remediation tracking, and audit preparation. Achieved 100 percent audit readiness for first-time certification.

Archer IRM Rollout

3-month rollout

- Served as platform administrator and business owner for deployment and administration. Automated risk-register workflows, regulatory reporting, and compliance dashboards, and reduced manual reporting effort by 60 percent.

Vulnerability Management Program

Ongoing program

- Applied Qualys VMDR across 500+ assets, risk-ranked vulnerabilities using risk quantification, coordinated remediation, and reduced critical exposures by 45 percent.

LEADERSHIP AND KEY ACHIEVEMENTS

- Led cross-functional GRC and security activities across banking and fintech environments, coordinating technical and business stakeholders in teams of 8-12 members.
- Reduced SOC incident escalations to Level 3 by 40 percent through playbook standardization and analyst coaching, and reduced manual SOC triage workload by 50 percent through Cortex XSOAR automation.
- Improved policy adherence by 35 percent through targeted compliance awareness sessions delivered to 200+ employees.
- Achieved zero major non-conformities across coordinated external audit activities.
- Directed risk remediation and audit closure activities to meet regulatory and business deadlines.

TRAINING AND AWARENESS

- Delivered compliance and information security awareness workshops for client staff across banking and fintech sectors.
- Trained Level 1 SOC analysts on alert triage logic, investigation methodology, SIEM usage, and escalation criteria.
- Conducted phishing awareness sessions for 100+ employees.

CERTIFICATIONS

GRC and Compliance: ISO 27001 LA and LI, ISO 27701 LI, GRCP, GRCA, IDPP, IRMP, GDPR, SOC 2 Implementer, IAAP, ICEP, IAIP, IPMP

Offensive Security: eWAPTX, eCPPT, eMAPT, eJPT, CAP (Certified AppSec Practitioner)

SOC and Incident Response: eCIR, eCDFP, eCTHP, Cortex XSOAR 6.2 (EDU-380, Palo Alto), Cyber Threat Intelligence 101

Networking and Cloud: NSE 1, NSE 2, NSE 3 (Fortinet), Palo Alto: Network Security, Cloud Security, SOC Fundamentals

EDUCATION

Bachelor of Science (B.Sc.) Computer Science

Modern University for Technology and Information (MTI), University of Wales | January 2020

ADDITIONAL TECHNICAL SKILLS

Programming and Infrastructure: Python, Java, C#, Windows Server, Active Directory, Linux

Security Platforms: QRadar, Splunk, Wazuh, Cortex XSOAR, Trellix, Qualys VMDR, Archer IRM, ServiceNow GRC

LANGUAGES

Arabic: Native | **English:** Professional Working Proficiency

REFERENCES

Available upon request.